

**SYSTEM AND ORGANIZATION
CONTROLS 2 (SOC 2) TYPE 2 REPORT**

Report on the Bitwarden Inc. Password Management System

For the Period July 1, 2023, to June 30, 2024

SYSTEM AND ORGANIZATION CONTROLS 2 (SOC 2) TYPE 2 REPORT

Report on the Bitwarden Inc. Description of Its Password Management System and on the Suitability of the Design and Operating Effectiveness of Its Controls Relevant to Security and Confidentiality Throughout the Period July 1, 2023, to June 30, 2024



Bitwarden Inc.
1 N. Calle Cesar Chavez, Suite 102
Santa Barbara, CA 93103

Tel: +1.904.337.9364

www.bitwarden.com



Table of Contents

Section I – Assertion of Bitwarden Inc. Management	1
Section II – Independent Service Auditor’s Report	4
Section III – Bitwarden Inc. Description of its Password Management System Throughout the Period July 1, 2023, to June 30, 2024.....	9
Company Background.....	10
Services Provided	12
Components of the System	14
Principal Service Commitments and System Requirements.....	18
Complementary User Entity Controls	20
Complementary Subservice Organization Controls	21
Trust Services Criteria.....	22
Section IV - Trust Services Criteria for Security and Confidentiality, Related Controls, and Tests of Controls	24

Section I – Assertion of Bitwarden Inc. Management

Assertion of Bitwarden Inc. Management

We have prepared the accompanying description of the Bitwarden Inc. (Bitwarden) Password Management System titled "Bitwarden Inc. Description of its Password Management System Throughout the Period July 1, 2023, to June 30, 2024", (description) based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report* (AICPA, *Description Criteria*) (description criteria). The description is intended to provide report users with information about the Password Management System that may be useful when assessing the risks arising from interactions with the Bitwarden system, particularly information about system controls that Bitwarden has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality, (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*, (AICPA, *Trust Services Criteria*).

Bitwarden utilizes two nationally known cloud service providers, and a cloud-based performance and reliability service, as subservice organization providers. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Bitwarden, to achieve Bitwarden service commitments and system requirements based on the applicable trust services criteria. The description presents Bitwarden controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Bitwarden controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Bitwarden, to achieve Bitwarden service commitments and system requirements based on the applicable trust services criteria. The description presents Bitwarden controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Bitwarden controls.

We confirm, to the best of our knowledge and belief, that

- a. the description presents Password Management System that was designed and implemented throughout the period July 1, 2023, to June 30, 2024, in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Bitwarden service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the subservice organization and user entities applied the complementary controls assumed in the design of Bitwarden controls throughout that period.
- c. the controls stated in the description operated effectively throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Bitwarden service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of Bitwarden controls operated effectively throughout that period.



Mr. Michael Crandell, CEO

Bitwarden Inc.

August 16, 2024

Section II – Independent Service Auditor’s Report

Independent Service Auditor's Report

To: Management of Bitwarden Inc.

Scope

We have examined the Bitwarden Inc. (Bitwarden) accompanying description of its Password Management System titled "Bitwarden Inc. Description of its Password Management System Throughout the Period July 1, 2023, to June 30, 2024", (description) based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Service Organization's System in a SOC 2 Report* (AICPA, *Description Criteria*), (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Bitwarden service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

Bitwarden utilizes two nationally known cloud service providers, and a cloud-based performance and reliability service, as subservice organization providers. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at Bitwarden, to achieve Bitwarden service commitments and system requirements based on the applicable trust services criteria. The description presents Bitwarden controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of Bitwarden controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Bitwarden, to achieve Bitwarden service commitments and system requirements based on the applicable trust services criteria. The description presents Bitwarden controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Bitwarden controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such controls.

Service organization's responsibilities

Bitwarden is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Bitwarden service commitments and system requirements were achieved. Bitwarden has provided the accompanying assertion titled "Assertion of Bitwarden Inc. Management" (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. Bitwarden is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service auditor's responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the engagement.

An examination of the description of a service organization's system and the suitability of the design and operating effectiveness of controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design and operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of tests of controls

The specific controls we tested, and the nature, timing, and results of those tests are listed in section IV.

Opinion

In our opinion, in all material respects,

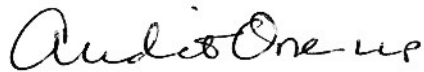
- a. the description presents the Bitwarden Password Management System that was designed and implemented throughout the period July 1, 2023, to June 30, 2024, in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Bitwarden service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the subservice organization and user entities applied the complementary controls assumed in the design of Bitwarden controls throughout that period.
- c. the controls stated in the description operated effectively throughout the period July 1, 2023, to June 30, 2024, to provide reasonable assurance that Bitwarden service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of Bitwarden controls operated effectively throughout that period.

Restricted use

This report, including the description of tests of controls and results thereof in section IV, is intended solely for the information and use of Bitwarden, user entities of the Bitwarden Password Management System during some or all of the period July 1, 2023, to June 30, 2024, business partners of Bitwarden subject to risks arising from interactions with the Password Management System, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties
- Internal control and its limitations
- Complementary user entity controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.



Campbell, California

August 16, 2024

**Section III – Bitwarden Inc. Description of its
Password Management System Throughout the
Period July 1, 2023, to June 30, 2024**

Bitwarden Inc. Description of its Password Management System Throughout the Period July 1, 2023, to June 30, 2024

Company Background

Bitwarden is an open source password management solution for individuals, teams, and business organizations available in both free and paid plans. Bitwarden was created by Kyle Spearrin in 2016.

Today the company is headquartered in Santa Barbara, California with a global distributed team. Bitwarden serves large and small companies around the world as well as our base of individual users.

Company Management

Michael Crandell, Chief Executive Officer

Michael is the chief executive officer at Bitwarden driving overall company strategy and growth.

Before Bitwarden, Michael was the CEO and co-founder of RightScale where he led the vision and direction for the company as a cloud management platform during the first decade of cloud computing. He grew the company to 250 employees and a successful exit to Flexera in 2018.

Prior to RightScale, Michael served as chief executive officer at several Internet software-as-a-service (SaaS) companies and as vice president of software and executive vice president at eFax.com, where he was part of the executive team that took the company public.

Michael received his bachelor's degree from Stanford University and completed graduate studies at Harvard University. He began his career as a software engineer, self-taught, coding in assembly language.

Kyle Spearrin, Founder and Chief Technology Officer

Kyle is the founder and chief technology officer of Bitwarden and currently leads all engineering and product efforts.

Before Bitwarden, Kyle was a software architect and engineering lead at iMobile3, a payment solutions company, where he focused on cloud infrastructure, mobile applications, and security for credit card processing.

Kyle previously founded companies in hosting and web services and has been a builder of online tools since he started organizing gaming communities in high school.

Kyle holds a bachelor's degree in Computer Science from the University of Florida.

Gary Orenstein, Chief Customer Officer

Gary is the chief customer officer at Bitwarden leading the go to market efforts across customer success, marketing, and sales.

Before Bitwarden, Gary served in executive marketing and product roles at enterprise infrastructure companies Yellowbrick Data and MemSQL, and flash memory pioneer Fusion-io which went public during his tenure there. Earlier in his career he led marketing at Compellent which after its IPO was acquired by Dell.

Gary holds a bachelor's degree from Dartmouth College and a master's in business administration from The Wharton School at the University of Pennsylvania.

Matt Cillis, Chief Sales Officer

Matt is the chief sales officer at Bitwarden leading the sales team.

Before Bitwarden, Matt served in executive sales roles at Splunk, CloudBees, and Instana. Earlier in his career he led teams at Dell focused on government and global accounts.

Matt holds a bachelor's degree from Clarkson University and a master's in engineering from Cornell.

Stephen Morrison, Chief Financial Officer

Steve joined Bitwarden in 2019 and leads the accounting, finance, legal and human resources functions.

Previously, Steve was CFO at RightScale, Inc. where he led the strategic sale of the company to Flexera, Inc. Before that, Steve was CFO at Butler America, LLC, a leading outsourcing firm, where he led the strategic sale of the aerospace engineering and defense division and the financial sale of the company's healthcare unit. He has held CFO roles at several other technology firms including ValenTx in medical technology, SmartReceipt in SaaS marketing, and 724 Solutions focused on mobile technology.

Originally from Canada, Steve moved to Santa Barbara 2003 after spending two years in Hong Kong while at 724 Solutions. He holds a BA from Western University in London, Ontario and an MBA from the Richard Ivey School of Business at Western.

Services Provided

Bitwarden provides a comprehensive solution for password management.

User view

Users primarily interact with Bitwarden through our client applications. In order to access Bitwarden client applications, users must create a login and master password. This information is used both for authenticating into Bitwarden, as well as to create a unique encryption key for each individual user. The encryption key is used to encrypt passwords, files, and other sensitive data the user selects to store in the Bitwarden Vault.

When interacting with Bitwarden applications, all Vault data is encrypted locally as it is stored, and Vault data remains encrypted for syncing. Thus, Bitwarden utilizes end-to-end encryption in the transmission and storage of all sensitive user data.

Bitwarden Client Applications

Bitwarden client applications span virtually all endpoint devices:

- Mobile for iOS and Android devices
- Desktop for Windows, MacOS, and Linux operating systems
- Browser Extensions for Chrome, Safari, Firefox, Edge, Brave, Opera and other web browsers
- Command Line Interface
- Web Application

All Vault data is encrypted and decrypted in the client applications with access granted via the user email and master password. Bitwarden as a company has no access to unencrypted Vault user data.

Bitwarden Extensions

Bitwarden also includes extensions such as:

- Directory Sync with a range of directory services such as
- Active Directory
- Any LDAP-based directory
- Azure Active Directory
- G Suite (Google)
- Okta
- A RESTful API is available at docs.bitwarden.com

Bitwarden Cloud

Bitwarden Cloud is available to all Bitwarden users as a means to synchronize devices. Bitwarden Cloud runs on Microsoft Azure.

Self-hosted Installation

Bitwarden is also available for self-hosted installation through a simplified Docker deployment.

Company Differentiators

Bitwarden is the only password management solution that is available as open source software and can be deployed as a service in the cloud, or self-hosted wherever customers choose, such as behind their firewall.

Components of the System

Management Controls

Control Environment

Board of Directors and Executive Oversight: The Company's board of directors conducts quarterly meetings. In addition, processes are in place to ensure that any sensitive information, investigations, and improper acts by or within the Company are reported to the board of directors in a timely manner.

Organizational Structure: The responsibilities of key positions within the Company are clearly defined and communicated. The Company has a hierarchical organizational structure that supports the open and continuous communication of information between leadership and its support staff. The hierarchy allows for clear direction to be communicated from executive management throughout the Company to support the overall objectives and direction of the Company.

Management Philosophy: Management's policies and communications are directed at ensuring that the company's personnel (i) understand the company's objectives; (ii) know how their individual actions interrelate and contribute to those objectives; and (iii) recognize how and for what they will be held accountable.

Management instills a philosophy that enables employees to share in the success and growth of the Company. A highly skilled and diverse group of employees comprises the organization's management team, individuals who are ultimately responsible for the vision and direction of the Company. Management members meet on a structured, routine basis to discuss a range of topics and are also responsible for establishing policies and addressing operational, financial, and social aspects of the organization.

Human Resource Management: The Company's management understands that a secure, quality operation requires an ethical, responsible, and competent staff. The Company maintains a thorough set of policies and practices to meet this objective including:

- Comprehensive employee background checks
- Hiring standards are established with emphasis on prior work experience, qualifications, and past accomplishments
- New hire orientation with training sessions addressing all essential organizational elements and department level orientation specific to respective roles
- Employee performance management process includes periodic assessments and real-time feedback
- Annual compliance training

Company policies and standards are clearly communicated to employees through formal documentation, close supervision, and training. Employees are provided a comprehensive employee handbook that covers a wide range of control considerations, clearly stated disciplinary procedures, and grounds for termination. Documented policies include:

- At-will employment policy
- Code of ethics
- Acceptable use
- Information/data security
- Confidentiality/non-disclosure of Company and client information
- Possession and use of company property
- Internet, email, and phone use
- Safety standards

Employee Training

Business Development: The sales staff is responsible for actively pursuing new business opportunities to help grow the organization. The team communicates openly and frequently with other members of the management team regarding business development and market penetration, and also discusses labor, capacity, productivity measures, and short-term and long-term planning when applicable. The Company actively assesses the risks of a potential decline or growth in sales and how it may affect the organization as a whole.

Financial Management: Finance and accounting employees are responsible for payments of organizational fixed and variable costs, tracking and reporting on key financial metrics, building cash flow projection models, budgeting, and financial regulatory compliance, collecting payments from clients, and maintaining all other financial activities. This team continually monitors and evaluates risk assessment concerning cash flows and the ability to meet mandatory expenses. Senior management also routinely addresses issues such as lines of credit, cash reserves, and other financial requirements. Annual budgets are created each fiscal year and reviewed on an ongoing basis.

Budgetary Process: The budgetary process encompasses all aspects of the financial reporting, including the creation of a budget book that details each division's budgeted monthly client revenue; a headcount report, including additions and deletions; balance sheet; cash flow; capital expenditures; roll-forward from prior year, including explanations of variances; and comparison to prior year actual, budget, and forecast. The Finance team works with each individual department manager to develop their respective budget then completes a review with the department manager to finalize the plan. The budget is then reviewed at the senior management level with the CEO. Upon completion, the budget is presented to the executive board by the leadership team for final approval.

Communication: The Company conducts recurring meetings to identify and address significant issues affecting the Company's operations. As business and development plans are established, meetings are held throughout the Company to report results achieved and communicate defined goals. Informal meetings provide the vehicle for management to communicate and respond to operational tasks and issues. At all corporate levels, the Company has established communication channels to promote and distribute information up and down the defined management structure. The Company embraces a belief that information should flow in an open environment, allowing discussion on a wide range of topics and subject matter by all employees.

Mission and Values: The Company has engaged in a Company-wide process of defining the mission and values statements of the Company and reviews those statements on a regular basis with existing and new employees.

Policy Management: Policy and procedure documents inform employees of their responsibility within the workplace environment and professional conduct expectations. Each department has access to work instruction documents pertaining to their respective roles and duties and how they should be performed. Revisions to corporate policies and procedures are readily available through the Company Google Docs and are distributed to relevant employees in a timely manner. Each policy and procedure is subject to an annual review and must be approved by respective managers.

Monitoring Controls: The Company maintains internal reporting, monitoring, and evaluation procedures to identify deviations from internal controls; and maintains a process to effectively report these deficiencies to the appropriate departments. The Company's monitoring procedures include:

- Goal setting and periodic review meetings with all employees
- Analysis of and appropriate follow-up on operating reports or metrics that might identify anomalies indicative of a control failure
- Supervisory reviews of controls, such as reconciliation reviews, as a normal part of processing

The assessment of compliance risk and ongoing corrective actions established by an: 1) annual risk assessment; and 2) ongoing quality control, quality assurance, and departmental monitoring.

The Company monitors internal control systems by conducting monitoring activities across the organization. Internal control deficiencies are immediately reported upstream to management where corrective action is applied. More serious matters are escalated to top-level management and immediate action is taken. Monitoring activities over internal controls are included in the following functional areas:

- Sales and Marketing
- Information Technology
- Finance and Accounting
- Daily Operations and Transaction Processing Environment

Security Controls:

Bitwarden security controls include but are not limited to:

- Logical access controls
- Data Security / Data Encryption
- Data Protection / Data Privacy
- Data Protection in Transit
- Data Protection at Rest
- Password hashing / Key derivation / Key Management and Key Storage

Please refer to the Bitwarden Security page for additional information

<https://bitwarden.com/help/security/>

Business Continuity and Disaster Recovery Program

Bitwarden employs a full range of disaster recovery and business continuity practices from Microsoft Azure that are built into the Bitwarden Cloud. This includes high availability and backup services for our application and database tiers. A combination of manual and automated monitoring of the Bitwarden Cloud infrastructure provides a comprehensive and detailed view of system health as well as proactive alerts on areas of concern. Issues are surfaced quickly so that our infrastructure team can effectively respond and mitigate problems with minimal disruption.

Customer / Client Support

Escalation Procedures are invoked to address any production processing issues. Clients are contacted if there are any quality issues or production delays that may affect agreed upon service levels.

Service Level Management: The Customer Support Manager monitors and reports on the achievement of specified performance criteria and takes corrective action when needed.

Principal Service Commitments and System Requirements

Bitwarden designs its processes and procedures related to the system to meet its objectives for its password management services. Those objectives are based on the service commitments that Bitwarden makes to user entities, the laws and regulations that govern the provision of the password management services, and the financial, operational, and compliance requirements that Bitwarden has established for the services. The password management services of Bitwarden are subject to the relevant regulatory and industry information and data security requirements in which Bitwarden operates

The security and confidentiality commitments to user entities are documented and communicated in customer agreements, sales and website documentation, and company policies. The principal security and confidentiality commitments are standardized and include, but are not limited to, the following:

- Security: Bitwarden maintains a robust information security program that includes:
 - Background checks conducted as part of the hiring process for employees and contractors
 - Security awareness training, and relevant compliance training provided at time of hire and renewed annually for all employees and contractors
 - Policies and procedures governing the security program reviewed and updated on an annual basis
 - Operational and technical controls in place to ensure confidential data is protected from unauthorized disclosure, use, modification, or destruction.
 - Independent third party security risk assessments performed on an annual basis
- Confidentiality: Bitwarden considers and classifies all personally identifiable customer/client data that is processed on its production information systems as Confidential.

Bitwarden establishes operational requirements that support the achievement of security commitments, relevant laws and regulations, and other system requirements. Such requirements are communicated in Bitwarden's system policies and procedures, system design documentation, and contracts with customers. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed and how employees are hired and trained. In addition to these policies, standard operating procedures have been documented on how to carry out specific manual and automated processes required in the operation and development of the password management system.

System Incident Disclosures

No system incidents occurred that were the result of controls that were not suitably designed or otherwise resulted in a significant failure of the achievement of one or more of the service commitments

Significant Changes During the Review Period

There were no significant changes that are likely to affect users' understanding of how the in-scope systems are used to provide the services covered by this examination during the review period.

Complementary User Entity Controls

The Bitwarden Password Management System was designed with the assumption that certain policies, processes, and controls would be implemented by user entities. In certain situations, the implementation of specific controls by the user entity is necessary to achieve certain criteria included in this report.

This section describes additional policies, processes, and controls, that should be in operation at the user entity to complement the controls performed by Bitwarden. However, there may be control objectives or related controls not identified in this report, which may be appropriate for a specific user entity's operation. The complementary user entity control considerations listed below should not be considered a complete or comprehensive list that should be employed by user entities.

Independent auditors or user entities should consider whether the following controls have been placed in operation by the user entity:

- User entities should comply with all Bitwarden terms and conditions documented here <https://bitwarden.com/terms/> **(CC 2.2)**
- User entities should review functionality changes, product level changes and enhancements and report if there are any incidents impacting Security and Confidentiality due to changes made by Bitwarden. **(CC 7.3, CC 7.4, CC 7.5)**
- User entities should use secure SSL/TLS v1.2 encrypted mechanisms to transfer data to Bitwarden. **(CC 6.7)**
- Controls are in place to ensure consistent data file delivery **(CC 6.7)**
- Controls are in place to ensure that, once client administrator accounts are enabled, clients are responsible for administering access and additional user accounts for their own employees **(CC 6.8)**

Complementary Subservice Organization Controls

Management's description of the service organization's system and the scope of the service auditor's engagement indicates that certain control objectives may only be met if corresponding controls at the Subservice Organization level are implemented, suitably designed, and effectively operating. The following controls must be assumed by the subservice organization to meet these criteria:

- Physical access controls should restrict access to datacenter locations and storage locations to safeguard servers and associated infrastructures within the datacenter facility. **(CC 6.4, CC 6.5)**
- Logical access security controls should be configured to prevent unauthorized access to the firewall rules and vulnerability scanning templates defined and maintained for service organizations. **(CC 4.1, CC 6.1, CC 7.1)**
- Revoking access to infrastructure utilized by the service organization based on access levels approved by the service organization. **(CC 6.5)**
- Restricting logical access to infrastructure utilized by the service organization based on access levels approved by the service organization. **(CC 6.1)**
- The monitoring of infrastructure components utilized by the service organization for security or hardware incident, and maintenance of appropriate incident escalation procedures to alert the service organization if necessary. **(CC 6.1)**
- Ensuring the validity and accuracy of user access reports provided to the service organization. **(CC 6.2)**
- Ensuring that infrastructure software utilized by the service organization is kept up to date and patched. **(CC 6.7, CC 6.8)**
- Environmental control mechanisms should protect datacenter locations, storage locations and infrastructures from certain environmental threats. **(CC 6.4)**

Bitwarden utilizes two nationally known cloud service providers, and a cloud-based performance and reliability service, as subservice organization providers. All subservice organizations used by Bitwarden have met a minimum of SOC 1 certification. Bitwarden performs a review of attestation reports for the above service providers on an annual basis. This description does not include the control objectives and related controls of these subservice providers.

Trust Services Criteria

Trust Services are a set of professional attestation and advisory services based on a core set of criteria that address the risks and opportunities of IT-enabled systems and privacy programs. The following criteria are being used in the performance of this trust services engagement:

- Security. The system is protected against unauthorized access (both physical and logical)
- Confidentiality. Information designated as confidential is protected as committed or agreed

Security

The system is protected against unauthorized access (both physical and logical).

The security criteria refers to the protection of the system components from unauthorized access, both logical and physical. In e-commerce and other systems, the respective parties wish to ensure that information provided is available only to those individuals who need access to complete the transaction or services or follow up on questions or issues that may arise. Information provided through these systems is susceptible to unauthorized access during transmission and while it is stored on the other party's systems. Limiting access to the system components helps prevent potential abuse of system components, theft of resources, misuse of software, and improper access to, use, alteration, destruction, or disclosure of information. Key elements for the protection of system components include permitting authorized access and preventing unauthorized access to those components.

Confidentiality

Information designated as confidential is protected as committed or agreed.

The confidentiality criteria focuses on information designated as confidential. Unlike personal information, which is being defined by regulation in a number of countries worldwide and is subject to the privacy criteria, there is no widely recognized definition of confidential information. In the course of communicating and transacting business, partners often exchange information they require to be maintained on a confidential basis. In most instances, the respective parties wish to ensure that the information they provide is available only to those individuals who need access to complete the transaction or resolution on any questions that arise. To enhance business partner confidence, it is important that the business partner is informed about the entity's confidentiality practices. The entity needs to disclose its practices relating to the manner in which it provides for authorized access to and uses and shares information designated as confidential.

Security Criteria and Common Criteria Table

Security Criteria Table

The system is protected against unauthorized access (both physical and logical)

CC 1.0 Common Criteria Related to Control Environment

CC 2.0 Common Criteria Related to Communication and Information

CC 3.0 Common Criteria Related to Risk Assessment

CC 4.0 Common Criteria Related to Monitoring Activities

CC 5.0 Common Criteria Related to Control Activities

CC 6.0 Common Criteria Related to Logical and Physical Access Controls

CC 7.0 Common Criteria Related to System Operations

CC 8.0 Common Criteria Related to Change Management

CC 9.0 Common Criteria Related to Risk Mitigation

Confidentiality Criteria Table

Information designated as confidential is protected as committed or agreed.

C 1.0 Additional Criteria for Confidentiality

Section IV - Trust Services Criteria for Security, and Confidentiality, Related Controls, and Tests of Controls

Trust Services Criteria for Security, and Confidentiality, Related Controls, and Tests of Controls

CC 1.0 Common Criteria Related to Control Environment

CC 1.1 COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	The HR department performs background and reference checks when hiring employees. Background check is performed for every new hire.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten new hire Checkr reports to confirm the HR department performs background and reference checks when hiring employees. Background check is performed for every new hire.	No exceptions noted.
2	The Bitwarden employee handbook defines rules of conduct, code of personal and business conduct, and ethics.	We inspected the Bitwarden Company Handbook dated August 2023 and noted the Team Member Conduct and General Policies section, to confirm the Bitwarden employee handbook defines rules of conduct, code of personal and business conduct, and ethics.	No exceptions noted.
3	Personnel read and accept the code of conduct and ethical standards upon hire by signing the acknowledgement of receipt in the employee handbook.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten signed confirmation of handbook receipts in the audit period, to confirm personnel read and accept the code of conduct and ethical standards upon hire by signing the acknowledgement of receipt in the employee handbook.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Issues of employee's security noncompliance are dealt with through performance improvement plans, disciplinary hearings, or termination.	We inspected the Bitwarden Company Handbook dated August 2023 and noted the Prohibited Conduct section to confirm issues of employee's security noncompliance are dealt with through performance improvement plans, disciplinary hearings, or termination. Through corroborative inquiry we confirmed there were no violations in the review period.	No exceptions noted.
5	All new hires, i.e., employees and contractors, are required to sign confidentiality agreements that address their responsibilities for protecting customer and Bitwarden data.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten signed Proprietary Information and Inventions Agreements, to confirm all new hires, i.e., employees and contractors, are required to sign confidentiality agreements that address their responsibilities for protecting customer and Bitwarden data.	No exceptions noted.

CC 1.2 COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	The Bitwarden management team and board of directors meet quarterly to communicate information needed to fulfill their roles with respect to the achievement of the company's service commitments and system requirements.	We inspected four Bitwarden Board of Directors meeting agendas, and four Board of Directors meeting invites to confirm, the Bitwarden management team and Board of Directors meet quarterly to communicate information needed to fulfill their roles with respect to the achievement of the company's service commitments and system requirements.	No exceptions noted.
2	Management evaluates the need for additional tools and resources in order to achieve business objectives, during its ongoing and periodic business planning and budgeting process and as part of its ongoing risk assessment and management process.	We inspected the Information Security Policy dated June 26, 2024. We inspected ten weekly management meeting agendas to confirm, management evaluates the need for additional tools and resources in order to achieve business objectives, during its ongoing and periodic business planning and budgeting process and as part of its ongoing risk assessment and management process.	No exceptions noted.
3	Consolidated financial statements align with financial accounting principles, maintain materiality in financial statement presentation, and reflects underlying transactions and events.	We inspected the 2023 year ending balance sheet, to confirm consolidated financial statements align with financial accounting principles, maintain materiality in financial statement presentation, and reflects underlying transactions and events.	No exceptions noted.

CC 1.3 COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Roles and responsibilities are defined in written job descriptions and communicated to managers and their supervisors taking into consideration segregation of duties as necessary at the various levels of the organization and requirements relevant to security. Employee or contractor abilities are evaluated as part of the hiring or transfer process to ensure they meet those requirements.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten job descriptions to confirm roles and responsibilities are defined in written job descriptions and communicated to managers and their supervisors taking into consideration segregation of duties as necessary at the various levels of the organization and requirements relevant to security. We inspected ten job descriptions to confirm employee or contractor abilities are evaluated as part of the hiring or transfer process to ensure they meet those requirements.	No exceptions noted.
2	The Bitwarden organization chart defines system development, production operations, security and compliance reporting structures, and job responsibilities. Responsibilities of the system development, production operations, and security and compliance functions are included in company's policies.	We inspected the current organization chart in the Rippling application, to confirm the Bitwarden organization chart defines system development, production operations, security and compliance reporting structures, and job responsibilities. We inspected ten job descriptions to confirm responsibilities of the system development, production operations, and security and compliance functions are included in company's policies.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
3	Bitwarden evaluates its organizational structure, reporting lines, authorizations, and responsibilities, as part of its business planning process and as part of its ongoing risk assessment and management process. These are revised when necessary to help meet changing commitments and requirements.	We inspected the Risk Management Program dated June 25, 2024. We inspected the organization chart in the Rippling application. We inspected ten weekly management meeting agendas to confirm Bitwarden evaluates its organizational structure, reporting lines, authorizations, and responsibilities, as part of its business planning process and as part of its ongoing risk assessment and management process.	No exceptions noted.

CC 1.4 COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	The HR department performs background and reference checks when hiring employees. Background check is performed for every new hire.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten new hire Checkr reports to confirm the HR department performs background and reference checks when hiring employees. Background check is performed for every new hire.	No exceptions noted.
2	New hires are evaluated for the appropriate skills and experience to match Bitwarden job requirements.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten job descriptions to confirm new hires are evaluated for the appropriate skills and experience to match Bitwarden job requirements.	No exceptions noted.
3	Bitwarden provides training programs, including continuing education, and training, to ensure skill sets and technical competency of existing personnel and contractors are developed and maintained.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected various KnowBe4 training sessions and KnowBe4 reports, to confirm Bitwarden provides training programs, including continuing education, and training, to ensure skill sets and technical competency of existing personnel and contractors are developed and maintained.	No exceptions noted.

CC 1.5 COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	The Bitwarden employee handbook defines rules of conduct, code of personal and business conduct, and ethics.	We inspected the Bitwarden Company Handbook dated August 2023 and noted the Team Member Conduct and General Policies section, to confirm the Bitwarden employee handbook defines rules of conduct, code of personal and business conduct, and ethics.	No exceptions noted.
2	Personnel read and accept the code of conduct and ethical standards upon hire by signing the acknowledgement of receipt in the employee handbook.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten signed confirmation of handbook receipts in the audit period, to confirm personnel read and accept the code of conduct and ethical standards upon hire by signing the acknowledgement of receipt in the employee handbook.	No exceptions noted.
3	Issues of employee's security noncompliance are dealt with through performance improvement plans, disciplinary hearings, or termination.	We inspected the Bitwarden Company Handbook dated August 2023 and noted the Prohibited Conduct section to confirm issues of employee's security noncompliance are dealt with through performance improvement plans, disciplinary hearings, or termination. Through corroborative inquiry we confirmed there were no violations in the review period.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	All new hires, i.e., employees and contractors, are required to sign confidentiality agreements that address their responsibilities for protecting customer and Bitwarden data.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten signed Proprietary Information and Inventions Agreements, to confirm all new hires, i.e., employees and contractors, are required to sign confidentiality agreements that address their responsibilities for protecting customer and Bitwarden data.	No exceptions noted.
5	Roles and responsibilities are defined in written job descriptions and communicated to managers and their supervisors taking into consideration segregation of duties as necessary at the various levels of the organization and requirements relevant to security. Employee or contractor abilities are evaluated as part of the hiring or transfer process to ensure they meet those requirements.	We inspected the Bitwarden Company Handbook dated August 2023. We inspected ten job descriptions to confirm roles and responsibilities are defined in written job descriptions and communicated to managers and their supervisors taking into consideration segregation of duties as necessary at the various levels of the organization and requirements relevant to security. We inspected ten job descriptions to confirm employee or contractor abilities are evaluated as part of the hiring or transfer process to ensure they meet those requirements.	No exceptions noted.

CC 2.0 Common Criteria Related to Communication and Information**CC 2.1 COSO Principle 13:** The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	A privacy policy is maintained with representation from various cross-functional teams and external parties to identify and manage compliance with relevant statutory, regulatory, and contractual requirements.	We inspected the Privacy Policy dated April 2024, to confirm a privacy policy is maintained with representation from various cross-functional teams and external parties to identify and manage compliance with relevant statutory, regulatory, and contractual requirements.	No exceptions noted.
2	Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	No exceptions noted.
3	Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	We inspected the Information Security Policy dated June 26, 2024, to confirm Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Security policies are reviewed and approved on an annual basis.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm security policies are reviewed and approved on an annual basis.	No exceptions noted.
5	Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	No exceptions noted.

CC 2.2 COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	The Bitwarden management team and board of directors meet quarterly to communicate information needed to fulfill their roles with respect to the achievement of the company's service commitments and system requirements.	We inspected four Bitwarden Board of Directors meeting agendas and four Board of Directors meeting invites, to confirm the Bitwarden management team and Board of Directors meet quarterly to communicate information needed to fulfill their roles with respect to the achievement of the company's service commitments and system requirements.	No exceptions noted.
2	The Bitwarden organization chart defines system development, production operations, security and compliance reporting structures, and job responsibilities. Responsibilities of the system development, production operations, and security and compliance functions are included in company's policies.	We inspected the current organization chart in the Rippling application, to confirm the Bitwarden organization chart defines system development, production operations, security and compliance reporting structures, and job responsibilities. We inspected ten job descriptions to confirm responsibilities of the system development, production operations, and security and compliance functions are included in company's policies.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
3	Bitwarden evaluates its organizational structure, reporting lines, authorizations, and responsibilities, as part of its business planning process and as part of its ongoing risk assessment and management process. These are revised when necessary to help meet changing commitments and requirements.	We inspected the Risk Management Program dated June 25, 2024. We inspected the organization chart in the Rippling application. We inspected ten weekly management meeting agendas to confirm Bitwarden evaluates its organizational structure, reporting lines, authorizations, and responsibilities, as part of its business planning process and as part of its ongoing risk assessment and management process.	No exceptions noted.
4	A privacy policy is maintained with representation from various cross-functional teams and external parties to identify and manage compliance with relevant statutory, regulatory, and contractual requirements.	We inspected the Privacy Policy dated April 2024, to confirm a privacy policy is maintained with representation from various cross-functional teams and external parties to identify and manage compliance with relevant statutory, regulatory, and contractual requirements.	No exceptions noted.
5	Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
6	Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	We inspected the Information Security Policy dated June 26, 2024, to confirm Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	No exceptions noted.
7	Bitwarden maintains internal informational documentation describing the company's environment, its boundaries, user responsibilities and services.	We inspected the Bitwarden Company Handbook dated August 2023, the Information Security Policy dated June 26, 2024, the Deployment Footprint Diagram dated April 6, 2020, and the Bitwarden network topology diagram, to confirm Bitwarden maintains internal informational documentation describing the company's environment, its boundaries, user responsibilities and services.	No exceptions noted.
8	Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties, as necessary.	We inspected the Information Security Incident Management Policy dated March 4, 2024, to confirm Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary.	No exceptions noted.

CC 2.3 COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Consolidated financial statements align with financial accounting principles, maintain materiality in financial statement presentation, and reflects underlying transactions and events.	We inspected the 2023 year ending balance sheet, to confirm consolidated financial statements align with financial accounting principles, maintain materiality in financial statement presentation, and reflects underlying transactions and events.	No exceptions noted.
2	A privacy policy is maintained with representation from various cross-functional teams and external parties to identify and manage compliance with relevant statutory, regulatory, and contractual requirements.	We inspected the Privacy Policy dated April 2024, to confirm a privacy policy is maintained with representation from various cross-functional teams and external parties to identify and manage compliance with relevant statutory, regulatory, and contractual requirements.	No exceptions noted.
3	Prior to engaging Bitwarden services, customers are required to review and agree with security and privacy requirements including the acceptable use of data, etc. which are defined in the Bitwarden Terms of Service.	We inspected the Bitwarden Terms of Service dated June 1, 2017, to confirm prior to engaging Bitwarden services, customers are required to review and agree with security and privacy requirements including the acceptable use of data, etc. which are defined in the Bitwarden Terms of Service.	No exceptions noted.
4	Relevant documentation and procedures are available and communicated to customers via the Bitwarden website, including responsibilities and accountabilities on an ongoing basis.	We observed the Bitwarden public website and noted the help page to confirm that relevant documentation and procedures are available and communicated to customers via the Bitwarden website, including responsibilities and accountabilities on an ongoing basis.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
5	Critical customer issues are escalated and resolved by the customer success team based on established criteria.	We inspected the Customer Success Runbook. We inspected twelve monthly Helpdesk Performance reports to confirm Critical customer issues are escalated and resolved by the customer success team based on established criteria.	No exceptions noted.
6	Agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected ten service provider contracts and terms of service agreements, to confirm agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners.	No exceptions noted.

CC 3.0 Common Criteria Related to Risk Assessment

CC 3.1 COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Insurance is used to mitigate risk. Insurance coverage includes Technology E&O/ CyberMedia, D&O, Employment Practices liability.	We inspected the Risk Management Program dated June 25, 2024. We inspected the Hartford certificate of liability dated November 15, 2023, to confirm insurance coverage includes technology E&O/ cybermedia, D&O, and employment practices liability.	No exceptions noted.
2	Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	We inspected the Risk Management Program dated June 25, 2024, to confirm Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	No exceptions noted.

CC 3.2 COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden performs risk assessment at least annually covering security and confidentiality. Additionally to identify information systems that process relevant data into information to support the internal control and the achievement of service commitments and service requirements.	We inspected the Risk Management Program dated June 25, 2024, and the IT Risk Rating Model dated June 25, 2024. We inspected the Bitwarden Risk Register dated 2024, to confirm Bitwarden performs risk assessment at least annually covering security and confidentiality.	No exceptions noted.
2	The risk assessment is reviewed by management on an annual basis. The findings from the risk analysis are discussed and prioritized for remediation	We inspected the Risk Management Program dated June 25, 2024, and the IT Risk Rating Model dated June 25, 2024. We inspected the minutes from the Security Council meeting on June 27, 2024, to confirm the risk register is reviewed by management on an annual basis, and the findings from the risk analysis are discussed and prioritized for remediation	No exceptions noted.

CC 3.3 COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Consolidated financial statements align with financial accounting principles, maintain materiality in financial statement presentation, and reflects underlying transactions and events.	We inspected the 2023 year ending balance sheet, to confirm consolidated financial statements align with financial accounting principles, maintain materiality in financial statement presentation, and reflects underlying transactions and events.	No exceptions noted.
2	Management uses information technology tools including security systems, fraud detection and monitoring systems, and incident tracking systems to identify and manage fraud risk.	We inspected the Information Security Incident Management Policy dated March 4, 2024. We observed the HackerOne application and the Stripe application, to confirm management uses information technology tools including security systems, fraud detection and monitoring systems, and incident tracking systems to identify and manage fraud risk.	No exceptions noted.

CC 3.4 COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	We inspected the Risk Management Program dated June 25, 2024, to confirm Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	No exceptions noted.
2	Bitwarden performs risk assessment at least annually covering security and confidentiality. Additionally to identify information systems that process relevant data into information to support the internal control and the achievement of service commitments and service requirements.	We inspected the Risk Management Program dated June 25, 2024, and the IT Risk Rating Model dated June 25, 2024. We inspected the Bitwarden Risk Register dated 2024, to confirm Bitwarden performs risk assessment at least annually covering security and confidentiality.	No exceptions noted.
3	The risk assessment is reviewed by management on an annual basis. The findings from the risk analysis are discussed and prioritized for remediation	We inspected the Risk Management Program dated June 25, 2024, and the IT Risk Rating Model dated June 25, 2024. We inspected the minutes from the Security Council meeting on June 27, 2024, to confirm the risk register is reviewed by management on an annual basis, and the findings from the risk analysis are discussed and prioritized for remediation	No exceptions noted.

CC 4.0 Common Criteria Related to Monitoring Activities

CC 4.1 COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	On an annual basis, Bitwarden contracts with a third party to complete a SOC control assessment to identify exceptions with controls and to provide operational feedback on the internal control environment.	We inspected the Bitwarden Inc. SOC 2 audit report dated August 11, 2023, to confirm that on an annual basis, Bitwarden contracts with a third party to complete a SOC control assessment to identify exceptions with controls and to provide operational feedback on the internal control environment.	No exceptions noted.
2	On an annual basis, Bitwarden contracts with a third party to perform a penetration test to determine gaps in the technical environment.	We inspected the Cure53 Pentest Reports dated August 2023, December 2023, and March 2024, to confirm that on an annual basis, Bitwarden contracts with a third party to perform a penetration test to determine gaps in the technical environment.	No exceptions noted.
3	Related third-party and vendor systems are subject to review as part of the vendor risk management process. Attestation reports (SOC 2 reports) are obtained and evaluated when available.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected five subservice provider vendor monitoring folders, to confirm related third-party and vendor systems are subject to review as part of the vendor risk management process. We confirmed through corroborative inquiry that attestation reports (SOC 2 reports) are obtained and evaluated when available.	No exceptions noted.

CC 4.2 COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	The risk assessment is reviewed by management on an annual basis. The findings from the risk analysis are discussed and prioritized for remediation	We inspected the Risk Management Program dated June 25, 2024, and the IT Risk Rating Model dated June 25, 2024. We inspected the minutes from the Security Council meeting on June 27, 2024, to confirm the risk register is reviewed by management on an annual basis, and the findings from the risk analysis are discussed and prioritized for remediation	No exceptions noted.
2	Control deficiencies found during third party assessments are reviewed by management and corrective actions are taken to address the deficiencies in a timely manner.	We inspected the Information Security Policy dated June 26, 2024. We inspected the Risk Register dated 2024. We observed the Jira application to confirm control deficiencies found during third party assessments are reviewed by management and corrective actions are taken to address the deficiencies in a timely manner.	No exceptions noted.
3	Management tracks the status of all assessment deficiencies until satisfactorily resolved.	We inspected the Information Security Policy dated June 26, 2024. We inspected the Risk Register dated 2024. We observed the Jira application to confirm management tracks the status of all assessment deficiencies until satisfactorily resolved.	No exceptions noted.

CC 5.0 Common Criteria Related to Control Activities

CC 5.1 COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	No exceptions noted.
2	Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	We inspected the Information Security Policy dated June 26, 2024, to confirm Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
3	Security policies are reviewed and approved on an annual basis.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm security policies are reviewed and approved on an annual basis.	No exceptions noted.
4	Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	No exceptions noted.

CC 5.2 COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	No exceptions noted.
2	Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	We inspected the Information Security Policy dated June 26, 2024, to confirm Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	No exceptions noted.
3	Security policies are reviewed and approved on an annual basis.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm security policies are reviewed and approved on an annual basis.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	No exceptions noted.

CC 5.3 COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden maintains formal policies that provide guidance for information security within the organization and the supporting IT environment.	No exceptions noted.
2	Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	We inspected the Information Security Policy dated June 26, 2024, to confirm Bitwarden has documented and communicated security policies that define the information security rules and requirements for the service environment.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
3	Security policies are reviewed and approved on an annual basis.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm security policies are reviewed and approved on an annual basis.	No exceptions noted.
4	Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
5	Bitwarden has defined structures, reporting lines with assigned authority and responsibilities to appropriately meet requirements relevant to security, availability, confidentiality, and privacy.	We inspected the Information Security Policy dated June 26, 2024, and the organization chart in the Rippling application, to confirm Bitwarden has defined structures, reporting lines with assigned authority and responsibilities to appropriately meet requirements relevant to security, availability, confidentiality, and privacy.	No exceptions noted.
6	Bitwarden policy and procedure manuals are reviewed annually by management for consistency with the organization's risk mitigation strategy and updated as necessary for changes in the strategy.	We inspected the Risk Management Program dated June 25, 2024, the Information Security Policy dated June 26, 2024, the Password Policy dated June 25, 2024, the Information Classification Policy dated June 28, 2024, the Information Security Incident Management Policy dated March 4, 2024, the Access Control Policy dated June 18, 2024, and the Acceptable Use Policy dated June 25, 2024, to confirm Bitwarden policy and procedure manuals are reviewed annually by management for consistency with the organization's risk mitigation strategy and updated as necessary for changes in the strategy.	No exceptions noted.

CC 6.0 Common Criteria Logical and Physical Access Controls

CC 6.1: The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	A unique ID and password are assigned to Bitwarden employees for accessing network, applications, database, and supporting operating systems.	We inspected the Access Control Policy dated June 18, 2024. We observed the AWS application, the Azure application, and the Google Workspace application to confirm a unique ID and password are assigned to Bitwarden employees for accessing network, applications, database, and supporting operating systems.	No exceptions noted.
2	A master list of Bitwarden system components is maintained, and any additions and removals are tracked.	We inspected the Information Security Policy dated June 26, 2024. We inspected the Deployment Footprint Diagram dated April 6, 2020, and the Bitwarden network topology diagram, to confirm a master list of Bitwarden system components is maintained, and any additions and removals are tracked.	No exceptions noted.
3	Passwords for in-scope system components are configured according to Bitwarden password policy and employees are educated on best practices for choosing strong passwords.	We inspected the Information Security Policy dated June 26, 2024. We observed the AWS application, the Azure application, and the Google Workspace application, to confirm passwords for in-scope system components are configured according to Bitwarden password policy and employees are educated on best practices for choosing strong passwords. We noted that password settings for Azure are federated with Google Workspace.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Access for new users and changes in access for existing users of Bitwarden applications, network, database, and supporting operating systems must be approved by management.	We inspected the Information Security Policy dated June 26, 2024. We inspected ten Jira access change tickets, to confirm access for new users and changes in access for existing users of Bitwarden applications, network, database, and supporting operating systems must be approved by management.	No exceptions noted.
5	Administrative access to the service environment is controlled through defined interfaces that require authentication using appropriate credentials. Privileges (i.e., read, write) are restricted to authorized personnel through designated channels based on job responsibilities.	We inspected the Access Control Policy dated June 18, 2024. We observed the AWS application, the Azure application, and the Google Workspace application, to confirm administrative access to the service environment is controlled through defined interfaces that require authentication using appropriate credentials, and privileges are restricted to authorized personnel through designated channels based on job responsibilities.	No exceptions noted.
6	A termination checklist is completed, and access is revoked for employees within 24 hours as part of the termination process.	We inspected the Information Security Policy dated June 26, 2024. We observed ten Rippling application termination screens, and the Google Workspace application logs, to confirm a termination checklist is completed, and access is revoked for employees within 24 hours as part of the termination process.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
7	Administrator access to Bitwarden Cloud applications, operating system, network, and database is limited to authorized individuals.	We inspected the Access Control Policy dated June 18, 2024. We observed the AWS application, the Azure application, and the Google Workspace application to confirm administrator access to Bitwarden Cloud applications, operating system, network, and database is limited to authorized individuals.	No exceptions noted.
8	IT staff performs a quarterly access review for production systems to ensure that access is restricted appropriately.	We inspected the Access Control Policy dated June 18, 2024. We inspected four quarterly access review Jira tickets, to confirm IT staff performs a quarterly access review for production systems to ensure that access is restricted appropriately.	No exceptions noted.
9	Access to production systems is documented via a ticketing system.	We inspected the Access Control Policy dated June 18, 2024. We inspected ten Jira access request tickets to confirm access to production systems is documented via Asana utilizing on-boarding, off-boarding, and transfer templates	No exceptions noted.
10	Bitwarden permits remote access to the Bitwarden Admin Portal by authorized employees only over encrypted virtual private network (VPN) connection.	We inspected the Information Security Policy dated June 26, 2024. We observed the Zscaler application, to confirm Bitwarden permits remote access to the Bitwarden Admin Portal by authorized employees only over encrypted virtual private network (VPN) connection.	No exceptions noted.

CC 6.2: Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users, whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Access for new users and changes in access for existing users of Bitwarden applications, network, database, and supporting operating systems must be approved by management.	We inspected the Information Security Policy dated June 26, 2024. We inspected ten Jira access change tickets, to confirm access for new users and changes in access for existing users of Bitwarden applications, network, database, and supporting operating systems must be approved by management.	No exceptions noted.
2	Administrative access to the service environment is controlled through defined interfaces that require authentication using appropriate credentials. Privileges (i.e., read, write) are restricted to authorized personnel through designated channels based on job responsibilities.	We inspected the Access Control Policy dated June 18, 2024. We observed the AWS application, the Azure application, and the Google Workspace application, to confirm administrative access to the service environment is controlled through defined interfaces that require authentication using appropriate credentials, and privileges are restricted to authorized personnel through designated channels based on job responsibilities	No exceptions noted.
3	A termination checklist is completed, and access is revoked for employees within 24 hours as part of the termination process.	We inspected the Information Security Policy dated June 26, 2024. We observed ten Rippling application termination screens, and the Google Workspace application logs, to confirm a termination checklist is completed, and access is revoked for employees within 24 hours as part of the termination process.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Administrator access to Bitwarden Cloud applications, operating system, network, and database is limited to authorized individuals.	We inspected the Access Control Policy dated June 18, 2024. We observed the AWS application, the Azure application, and the Google Workspace application to confirm administrator access to Bitwarden Cloud applications, operating system, network, and database is limited to authorized individuals.	No exceptions noted.
5	IT staff performs a quarterly access review for production systems to ensure that access is restricted appropriately.	We inspected the Access Control Policy dated June 18, 2024. We inspected four quarterly access review Jira tickets, to confirm IT staff performs a quarterly access review for production systems to ensure that access is restricted appropriately.	No exceptions noted.
6	Access to production systems is documented via a ticketing system.	We inspected the Access Control Policy dated June 18, 2024. We inspected ten Jira access request tickets to confirm access to production systems is documented via Asana utilizing on-boarding, off-boarding, and transfer templates	No exceptions noted.

CC 6.3: The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Administrator access to Bitwarden Cloud applications, operating system, network, and database is limited to authorized individuals.	We inspected the Access Control Policy dated June 18, 2024. We observed the AWS application, the Azure application, and the Google Workspace application to confirm administrator access to Bitwarden Cloud applications, operating system, network, and database is limited to authorized individuals.	No exceptions noted.
2	IT staff performs a quarterly access review for production systems to ensure that access is restricted appropriately.	We inspected the Access Control Policy dated June 18, 2024. We inspected four quarterly access review Jira tickets, to confirm IT staff performs a quarterly access review for production systems to ensure that access is restricted appropriately.	No exceptions noted.
3	Access to production systems is documented via a ticketing system.	We inspected the Access Control Policy dated June 18, 2024. We inspected ten Jira access request tickets to confirm access to production systems is documented via Asana utilizing on-boarding, off-boarding, and transfer templates	No exceptions noted.

CC 6.4: The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden restricts physical access to offices and protected information assets (for example, offices, and other sensitive locations) to only authorized personnel to meet company objectives.	We inspected the Information Security Policy dated June 26, 2024, and the Bitwarden Company Handbook dated August 2023, to confirm Bitwarden restricts physical access to offices and protected information assets (for example, offices, and other sensitive locations) to only authorized personnel to meet company objectives.	No exceptions noted.
2	Bitwarden cloud computing providers implement physical access mechanisms (e.g., access card readers, biometric devices, man traps / portals, cages, locked cabinets) which restrict access to only authorized individuals.	We inspected the Information Security Policy dated June 26, 2024, the Bitwarden Company Handbook dated August 2023, and the Management of Third Party Services Policy dated June 13, 2024. We inspected four subservice cloud computing provider SOC reports to confirm Bitwarden cloud computing providers implement physical access mechanisms which restrict access to only authorized individuals.	No exceptions noted.

CC 6.5: The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	A data classification policy is in place to help ensure that confidential data is properly secured and restricted to authorized personnel.	We inspected the Information Classification Policy dated June 28, 2024, to confirm a data classification policy is in place to help ensure that confidential data is properly secured and restricted to authorized personnel.	No exceptions noted.
2	Formal data retention and disposal procedures are in place to guide the secure disposal of Bitwarden and Bitwarden customer data.	We inspected the Information Security Policy dated June 26, 2024, and the Bitwarden Terms of Service dated June 1, 2017, to confirm formal data retention and disposal procedures are in place to guide the secure disposal of Bitwarden and Bitwarden customer data.	No exceptions noted.
3	Prior to removal from company facilities, all digital media is completely sanitized to remove any data and software.	We inspected the Information Security Policy dated June 26, 2024. We inspected four subservice cloud computing provider SOC reports, to confirm that prior to removal from company facilities, all digital media is completely sanitized to remove any data and software.	No exceptions noted.

CC 6.6: The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden permits remote access to the Bitwarden Admin Portal by authorized employees only over encrypted virtual private network (VPN) connection.	We inspected the Information Security Policy dated June 26, 2024. We observed the Zscaler application, to confirm Bitwarden permits remote access to the Bitwarden Admin Portal by authorized employees only over encrypted virtual private network (VPN) connection.	No exceptions noted.
2	System firewalls are configured to limit unnecessary ports, protocols, and services.	We inspected the Information Security Policy dated June 26, 2024. We observed the Fastly application, and the Azure application, to confirm system firewalls are configured to limit unnecessary ports, protocols, and services.	No exceptions noted.
3	Bitwarden has deployed Transport Layer Security (TLS) for transmission of confidential and/or sensitive information over public networks.	We inspected the Information Security Policy dated June 26, 2024. We inspected production web site Qualys SSL scan reports to confirm, Bitwarden has deployed Transport Layer Security (TLS) for transmission of confidential and/or sensitive information over public networks.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Cryptographic controls are used for information protection within the Bitwarden platform and these controls are based on Bitwarden Cryptographic Policy and Key Management procedures.	We inspected the Information Security Policy dated June 26, 2024, and the Bitwarden Security Whitepaper, to confirm cryptographic controls are used for information protection within the Bitwarden platform and these controls are based on Bitwarden Cryptographic Policy and Key Management procedures.	No exceptions noted.
5	Secure file transfer protocols are deployed for transmission of confidential and/or sensitive information over public networks.	We inspected the Information Security Policy dated June 26, 2024. We inspected production web site Qualys SSL scan reports to confirm secure file transfer protocols are deployed for transmission of confidential and/or sensitive information over public networks.	No exceptions noted.
6	Intrusion detection systems are used to provide continuous monitoring of the Bitwarden network and prevention of potential security breaches.	We inspected the Information Security Policy dated June 26, 2024. We observed the Fastly application and the Microsoft Azure application to confirm, intrusion detection systems are used to provide continuous monitoring of the Bitwarden network and prevention of potential security breaches.	No exceptions noted.

CC 6.7: The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden has deployed Transport Layer Security (TLS) for transmission of confidential and/or sensitive information over public networks.	We inspected the Information Security Policy dated June 26, 2024. We inspected production web site Qualys SSL scan reports to confirm, Bitwarden has deployed Transport Layer Security (TLS) for transmission of confidential and/or sensitive information over public networks.	No exceptions noted.
2	Cryptographic controls are used for information protection within the Bitwarden platform and these controls are based on Bitwarden Cryptographic Policy and Key Management procedures.	We inspected the Information Security Policy dated June 26, 2024, and the Bitwarden Security Whitepaper, to confirm cryptographic controls are used for information protection within the Bitwarden platform and these controls are based on Bitwarden Cryptographic Policy and Key Management procedures.	No exceptions noted.
3	Secure file transfer protocols are deployed for transmission of confidential and/or sensitive information over public networks.	We inspected the Information Security Policy dated June 26, 2024. We inspected production web site Qualys SSL scan reports to confirm secure file transfer protocols are deployed for transmission of confidential and/or sensitive information over public networks.	No exceptions noted.

CC 6.8: The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Intrusion detection systems are used to provide continuous monitoring of the Bitwarden network and prevention of potential security breaches.	We inspected the Information Security Policy dated June 26, 2024. We observed the Fastly application and the Microsoft Azure application to confirm, intrusion detection systems are used to provide continuous monitoring of the Bitwarden network and prevention of potential security breaches.	No exceptions noted.
2	Bitwarden Cloud applications, customer sites, critical applications, and servers are continuously monitored using system monitoring applications that provide notification of system and application events to the Bitwarden Operations department for timely resolution.	We inspected the Information Security Policy dated June 26, 2024. We observed the Fastly application, and the Datadog application to confirm, Bitwarden Cloud applications, customer sites, critical applications, and servers are continuously monitored using system monitoring applications that provide notification of system and application events to the Bitwarden Operations department for timely resolution.	No exceptions noted.

CC 7.0 Common Criteria Related to System Operations

CC 7.1: To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Critical customer issues are escalated and resolved by the customer success team based on established criteria.	We inspected the Customer Success Runbook. We inspected twelve monthly Helpdesk Performance reports to confirm Critical customer issues are escalated and resolved by the customer success team based on established criteria.	No exceptions noted.
2	On an annual basis, Bitwarden contracts with a third party to perform a penetration test to determine gaps in the technical environment.	We inspected the Cure53 Pentest Reports dated August 2023, December 2023, and March 2024, to confirm that on an annual basis, Bitwarden contracts with a third party to perform a penetration test to determine gaps in the technical environment.	No exceptions noted.
3	Intrusion detection systems are used to provide continuous monitoring of the Bitwarden network and prevention of potential security breaches.	We inspected the Information Security Policy dated June 26, 2024. We observed the Fastly application and the Microsoft Azure application to confirm, intrusion detection systems are used to provide continuous monitoring of the Bitwarden network and prevention of potential security breaches.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Bitwarden Cloud applications, customer sites, critical applications, and servers are continuously monitored using system monitoring applications that provide notification of system and application events to the Bitwarden Operations department for timely resolution.	We inspected the Information Security Policy dated June 26, 2024. We observed the Fastly application, and the Datadog application to confirm, Bitwarden Cloud applications, customer sites, critical applications, and servers are continuously monitored using system monitoring applications that provide notification of system and application events to the Bitwarden Operations department for timely resolution.	No exceptions noted.
5	Events that affect production service availability of Bitwarden Cloud applications are identified, investigated, resolved, and documented according to procedure by the Bitwarden Operations department	We inspected the Information Security Incident Management Policy dated March 4, 2024. We observed the Azure application, the Fastly application, and the Opsgenie application, to confirm events that affect production service availability of Bitwarden Cloud applications are identified, investigated, resolved, and documented according to procedure by the Bitwarden Operations department	No exceptions noted.
6	Bitwarden monitors all system components through an automated management interface to log, track, and maintain all inventory components.	We observed the Azure application, to confirm Bitwarden monitors all system components through an automated management interface to log, track, and maintain all inventory components.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
7	Bitwarden monitors IT infrastructure availability and performance and generates alerts when specific predefined thresholds are met.	We observed the Fastly application, the Datadog application, the Azure application, the FreshPing application, the GitHub application, the HackerOne application, and the OpsGenie application to confirm, Bitwarden monitors IT infrastructure availability and performance and generates alerts when specific predefined thresholds are met.	No exceptions noted.
8	All incidents related to security are logged, tracked, and communicated to affected parties by management until resolved.	We inspected the Information Security Incident Management Policy dated March 4, 2024. We observed the Fastly application, the Datadog application, the Azure application, the FreshPing application, the GitHub application, the HackerOne application, and the OpsGenie application to confirm, to confirm all incidents related to security are logged, tracked, and communicated to affected parties by management until resolved.	No exceptions noted.

CC 7.2: The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties, as necessary.	We inspected the Information Security Incident Management Policy dated March 4, 2024, to confirm Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary.	No exceptions noted.
2	All incidents related to security are logged, tracked, and communicated to affected parties by management until resolved.	We inspected the Information Security Incident Management Policy dated March 4, 2024. We observed the Fastly application, the Datadog application, the Azure application, the FreshPing application, the GitHub application, the HackerOne application, and the OpsGenie application to confirm, to confirm all incidents related to security are logged, tracked, and communicated to affected parties by management until resolved.	No exceptions noted.

CC 7.3: The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties, as necessary.	We inspected the Information Security Incident Management Policy dated March 4, 2024, to confirm Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary.	No exceptions noted.

CC 7.4: The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties, as necessary.	We inspected the Information Security Incident Management Policy dated March 4, 2024, to confirm Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary.	No exceptions noted.
2	On an annual basis, Bitwarden contracts with a third party to perform a penetration test to determine gaps in the technical environment.	We inspected the Cure53 Pentest Reports dated August 2023, December 2023, and March 2024, to confirm that on an annual basis, Bitwarden contracts with a third party to perform a penetration test to determine gaps in the technical environment.	No exceptions noted.

CC 7.5: The entity identifies, develops, and implements activities to recover from identified security incidents.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties, as necessary.	We inspected the Information Security Incident Management Policy dated March 4, 2024, to confirm Bitwarden has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary.	No exceptions noted.
2	Bitwarden incorporates lessons learned from ongoing incident response activities into incident response procedures accordingly.	We inspected the Information Security Incident Management Policy dated March 4, 2024, to confirm Bitwarden incorporates lessons learned from ongoing incident response activities into incident response procedures accordingly.	No exceptions noted.

CC 8.0 Common Criteria Related to System Operations

CC 8.1: The entity authorizes, designs, develops, or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Scheduled changes are implemented into production only after approval. Emergency changes are completed on an as-needed basis and follow the Bitwarden documented change management process.	We observed the GitHub application, and noted ten change requests, to confirm scheduled changes are implemented into production only after approval. We inspected the Change Management Policy dated June 27, 2024, to confirm emergency changes are completed on an as-needed basis and follow the Bitwarden documented change management process.	No exceptions noted.
2	Responsibilities for submitting and approving production deployments are segregated within Bitwarden teams.	We inspected the Change Management Policy dated June 27, 2024. We observed the GitHub application, and noted ten change requests, to confirm responsibilities for submitting and approving production deployments are segregated within Bitwarden teams.	No exceptions noted.
3	Change requests are reviewed and approved by management or senior development team members.	We inspected the Change Management Policy dated June 27, 2024. We observed the GitHub application, and noted ten change requests, to confirm change requests are reviewed and approved by management or senior development team members.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Procedures for managing different types of changes to the Bitwarden platform have been documented and communicated.	We inspected the Change Management Policy dated June 27, 2024, to confirm procedures for managing different types of changes to the Bitwarden platform have been documented and communicated.	No exceptions noted.
5	The Bitwarden software and infrastructure change management process requires that change requests are: • Authorized • Formally documented • Tested prior to migration to production • Reviewed and approved	We inspected the Change Management Policy dated June 27, 2024. We observed the GitHub application, and noted ten change requests, to confirm the software and infrastructure change management process requires that change requests are authorized, formally documented, tested prior to migration to production, are reviewed and approved.	No exceptions noted.
6	Changes to baseline configurations require peer review and approval by the appropriate manager. No ad hoc applications and/or services may be run on production systems. All applications and services must follow the change management process and be approved by a manager.	We inspected the Information Security Policy dated June 26, 2024, to confirm changes to baseline configurations require peer review and approval by the appropriate manager, and no ad hoc applications and/or services may be run on production systems. We inspected the Change Management Policy dated June 27, 2024, to confirm all applications and services must follow the change management process and be approved by a manager.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
7	Bitwarden has adopted a formal systems development life cycle (SDLC) methodology that governs the development, acquisition, implementation, and maintenance of computerized information systems and related technology requirements.	We inspected the Change Management Policy dated June 27, 2024, to confirm Bitwarden has adopted a formal systems development life cycle (SDLC) methodology that governs the development, acquisition, implementation, and maintenance of computerized information systems and related technology requirements.	No exceptions noted.
8	Bitwarden maintains separate production and development environments. Changes to infrastructure or software are tested prior to implementation.	We inspected the Change Management Policy dated June 27, 2024. We observed the Azure application, and noted separate subscriptions, to confirm Bitwarden maintains separate production and development environments. Changes to infrastructure or software are tested prior to implementation.	No exceptions noted.
9	Code review or walkthrough is performed where applicable, such as high impact changes and these are performed by an appropriate peer based on the content of the change.	We inspected the Change Management Policy dated June 27, 2024, to confirm a code review or walkthrough is performed where applicable, such as high impact changes and these are performed by an appropriate peer based on the content of the change.	No exceptions noted.

CC 9.0 Common Criteria Related to System Operations

CC 9.1: The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Insurance is used to mitigate risk. Insurance coverage includes Technology E&O/ CyberMedia, D&O, Employment Practices liability.	We inspected the Risk Management Program dated June 25, 2024. We inspected the Hartford certificate of liability dated November 15, 2023, to confirm insurance coverage includes technology E&O/ cybermedia, D&O, and employment practices liability.	No exceptions noted.
2	Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	We inspected the Risk Management Program dated June 25, 2024, to confirm Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	No exceptions noted.
3	Bitwarden performs risk assessment at least annually covering security and confidentiality. Additionally to identify information systems that process relevant data into information to support the internal control and the achievement of service commitments and service requirements.	We inspected the Risk Management Program dated June 25, 2024, and the IT Risk Rating Model dated June 25, 2024. We inspected the Bitwarden Risk Register dated 2024, to confirm Bitwarden performs risk assessment at least annually covering security and confidentiality.	No exceptions noted.

CC 9.2: The entity assesses and manages risks associated with vendors and business partners.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected ten service provider contracts and terms of service agreements, to confirm agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners.	No exceptions noted.
2	Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	We inspected the Risk Management Program dated June 25, 2024, to confirm Bitwarden maintains a formal risk management program to continually discover, research, plan, resolve, monitor, and optimize information security risks that impact the company's business objectives, regulatory requirements, and customers.	No exceptions noted.
3	Related third-party and vendor systems are subject to review as part of the vendor risk management process. Attestation reports (SOC 2 reports) are obtained and evaluated when available.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected five subservice provider vendor monitoring folders, to confirm related third-party and vendor systems are subject to review as part of the vendor risk management process. We confirmed through corroborative inquiry that attestation reports (SOC 2 reports) are obtained and evaluated when available.	No exceptions noted.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
4	Contracts are in place with third-party Cloud Service providers which include provisions to provide fire suppression systems, air conditioning to maintain appropriate atmospheric conditions, Uninterruptible Power Supply (UPS) units, and redundant power supplies.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected four cloud computing provider contracts to confirm, contracts are in place with third-party cloud service providers which include provisions to provide fire suppression systems, air conditioning to maintain appropriate atmospheric conditions, Uninterruptible Power Supply (UPS) units, and redundant power supplies.	No exceptions noted.
5	Contracts with third-party Cloud Service providers include provisions requiring communication of incidents or events that impact production assets and/or customers to Bitwarden.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected four cloud service provider terms of service agreements to confirm contracts also include provisions requiring communication of incidents or events that impact production assets and/or customers to Bitwarden.	No exceptions noted.
6	Bitwarden has clauses in its agreements with vendors and business partners to terminate relationships when necessary.	We inspected the Management of Third Party Services Policy dated June 13, 2024. We inspected ten service provider terms of service agreements to confirm, Bitwarden has clauses in its agreements with vendors and business partners to terminate relationships when necessary.	No exceptions noted.

Additional criteria for “Confidentiality” Trust Criteria**C 1.0 Additional Criteria for Confidentiality**

C1.1: The entity identifies and maintains confidential information to meet the entity’s objectives related to confidentiality.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	A data classification policy is in place to help ensure that confidential data is properly secured and restricted to authorized personnel.	We inspected the Information Classification Policy dated June 28, 2024, to confirm a data classification policy is in place to help ensure that confidential data is properly secured and restricted to authorized personnel.	No exceptions noted.
2	Formal data retention and disposal procedures are in place to guide the secure disposal of Bitwarden and Bitwarden customer data.	We inspected the Information Security Policy dated June 26, 2024, and the Bitwarden Terms of Service dated June 1, 2017, to confirm formal data retention and disposal procedures are in place to guide the secure disposal of Bitwarden and Bitwarden customer data.	No exceptions noted.
3	Customer agreements stipulate the retention and disposal of confidential customer data.	We inspected the Bitwarden Terms of Service dated June 1, 2017, to confirm customer agreements stipulate the retention and disposal of confidential customer data.	No exceptions noted.

C 1.2: The entity disposes of confidential information to meet the entity's objectives related to confidentiality.

No.	Controls Specified by Bitwarden	AuditOne LLP Tests of Controls	Results of Tests
1	Formal data retention and disposal procedures are in place to guide the secure disposal of Bitwarden and Bitwarden customer data.	We inspected the Information Security Policy dated June 26, 2024, and the Bitwarden Terms of Service dated June 1, 2017, to confirm formal data retention and disposal procedures are in place to guide the secure disposal of Bitwarden and Bitwarden customer data.	No exceptions noted.
2	Prior to removal from company facilities, all digital media is completely sanitized to remove any data and software.	We inspected the Information Security Policy dated June 26, 2024. We inspected four subservice cloud computing provider SOC reports, to confirm that prior to removal from company facilities, all digital media is completely sanitized to remove any data and software.	No exceptions noted.
3	Customer agreements stipulate the retention and disposal of confidential customer data.	We inspected the Bitwarden Terms of Service dated June 1, 2017, to confirm customer agreements stipulate the retention and disposal of confidential customer data.	No exceptions noted.